Seguridad frontend en PharmaSoft

Login, sesión, interceptores, guards y permisos

Kevin Eduardo Del Carpio Alegría · Lenguaje de Programación II · Ciclo IV · 2026-2

1. Objetivo y alcance

Integrar la SPA Angular 22 con PharmaBackend seguro mediante autenticación JWT, persistencia temporal de sesión, vencimiento automático y autorización por permisos. La verificación sigue los 16 casos de la sesión 11: formulario, rutas, envío de token, F5, menú, controles por rol, cierre de sesión, token alterado y expiración.

La pantalla de login queda fuera del layout privado. Después de entrar, el encabezado muestra nombre, roles y hora de expiración. VENDEDOR usa el catálogo en lectura y consulta Ventas; ALMACENERO mantiene el catálogo sin acceder a Ventas; supervisor combina ambos conjuntos de permisos. Clientes y Reportes conservan sus rutas con CLIENTES_LEER y REPORTES_VER.

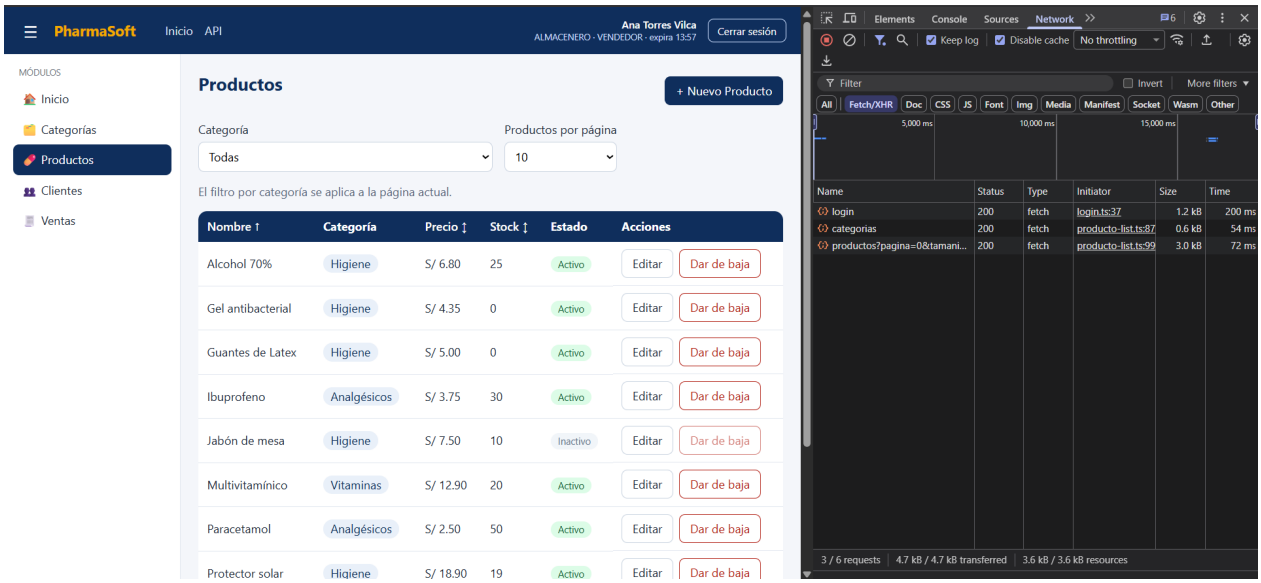


Figura 1. Supervisor: ambos roles en el encabezado, Ventas en el menú y acciones de edición del catálogo.

El criterio de éxito es que cada operación coincida con su regla. Un rechazo esperado de 401 o 403 demuestra que la restricción se aplica; no representa un fallo de la prueba.

2. Flujo de autenticación

El formulario valida los campos antes de enviar POST /api/v1/auth/login. AuthService guarda token, expiraEn, nombre, roles y permisos en un signal y en sessionStorage; la contraseña solo se envía para autenticar y no forma parte de la sesión almacenada. El login devuelve a la ruta interna indicada en returnUrl y descarta destinos externos.

Sesión, navegación y errores

3. Componentes de la solución

AuthService. Calcula expiraEn con la duración recibida, recupera la sesión tras F5 y descarta datos dañados o vencidos. Un temporizador limpia signal y sessionStorage al llegar al vencimiento; la navegación al login incorpora expirada=1 y la página actual como returnUrl. El cierre manual también cancela el temporizador.

Interceptores. authInterceptor añade Authorization: Bearer únicamente a la API, comprobando origen y límite de ruta, y excluye auth/login. errorInterceptor cierra una sesión ante un 401 de la API protegida, sin convertir un 401 de credenciales en una redirección. Un 403 se propaga al componente y conserva la sesión.

Guards. authGuard protege el layout y sus hijos; invitadoGuard impide volver al login con sesión vigente. permisoGuard usa data.permiso y presenta Acceso denegado. Las rutas de alta y edición exigen escritura además de los permisos del listado.

Interfaz reactiva. Sidebar filtra MENU con computed. La directiva *appSiPermiso incorpora o retira botones y columnas según los permisos del signal. Nuevo/Editar/Eliminar en categorías y productos requieren CATALOGO_ESCRIBIR; Nueva venta requiere VENTAS_REGISTRAR. El backend mantiene la protección efectiva aunque alguien modifique el navegador.

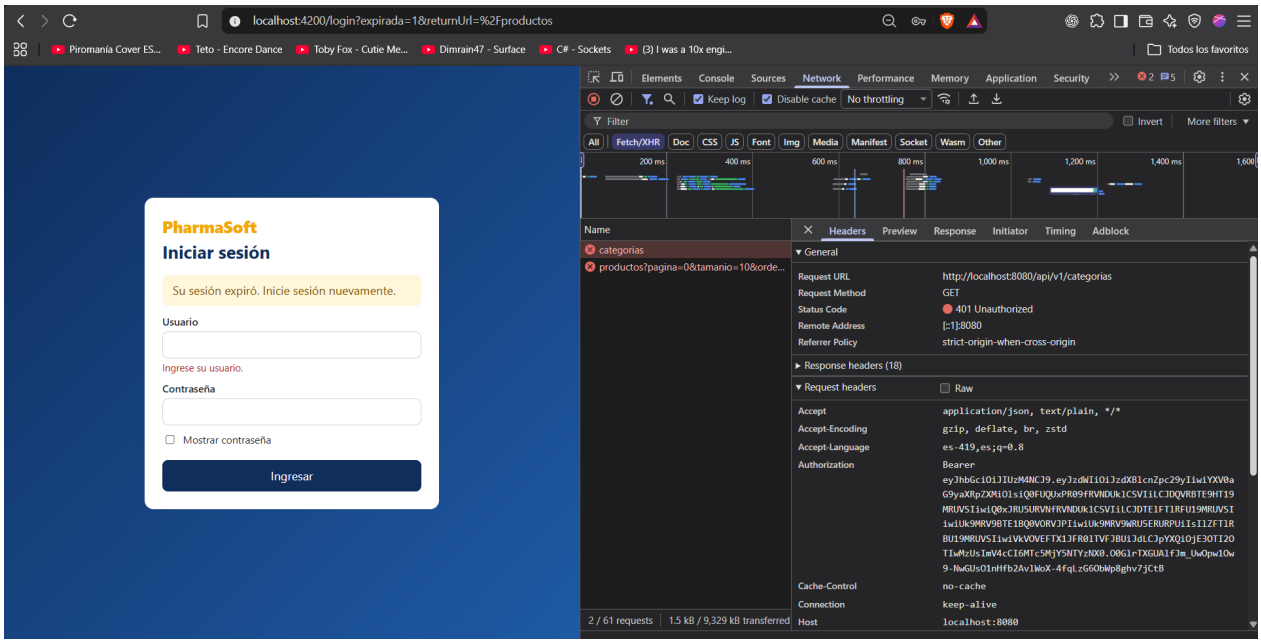


Figura 2. JWT alterado: respuesta 401, cierre de sesión y retorno al login conservando la ruta de Productos.

4. Diferencia entre 401 y 403

El caso 15 prueba el rechazo HTTP de un JWT alterado y la reacción del interceptor. El caso 10 prueba un bloqueo de navegación del guard antes de abrir el formulario. La consulta adicional de reportes devuelve 403 por falta de REPORTES_VER y conserva la pantalla del vendedor. Esa consulta se ejecuta con fetch; el comportamiento de errorInterceptor ante 403 se verifica además en la prueba automatizada de HttpClient.

La compilación de producción terminó correctamente y la regresión ejecutó 120 pruebas aprobadas en 30 archivos. Estos resultados automatizados complementan las comprobaciones manuales; no se cuentan como casos adicionales de la guía.

Resultados de las 16 pruebas

Los 16 casos presentan resultados conformes con las reglas comprobadas. Las referencias E enlazan cada caso con las figuras agrupadas de las páginas siguientes. Las vistas adicionales de lectura y del reporte 403 amplían la evidencia sin aumentar el número de casos base.

Caso	Comprobación	Resultado obtenido - Pasa	Evidencia
01	URL /ventas sin sesión	Login con returnUrl=%2Fventas.	E01
02	Formulario vacío	Dos mensajes obligatorios y ninguna petición de login.	E02
03	Contraseña incorrecta de admin	401 y mensaje genérico; permanece en login.	E03
04	Login de cuenta inactiva	401 con el mismo mensaje de credenciales.	E04-E05
05	Login de vendedor	200; vuelve a Ventas con nombre, rol y expiración.	E06-E07
06	Token en peticiones	GET productos 200 con Authorization Bearer; login separado del envío del token.	E06, E08-E09
07	Session storage	pharmasoft.sesion con token, expiraEn y permisos; sin password.	E10
08	Recarga F5 en Productos	Conserva sesión y página; consultas del catálogo 200.	E11
09	Catálogo del vendedor	Sin Nuevo producto ni Acciones; categorías también en lectura.	E12-E13
10	Ruta /productos/nuevo	Acceso denegado dentro del layout; conserva la sesión.	E14-E15
11	Visitar /login con sesión	Redirección a /inicio.	E16
12	Cerrar sesión	Login y eliminación de pharmasoft.sesion.	E17
13	Cuenta ALMACENERO	Ventas oculta y URL directa denegada; catálogo editable.	E18-E20
14	Cuenta supervisor	Unión de roles: Ventas y edición del catálogo.	E21
15	Alterar JWT y recargar	401; aviso de expiración y returnUrl a Productos.	E22-E24
16	Duración JWT de un minuto	Login con duración 60 s; cierre automático y retorno al login. Sesión posterior en Productos.	E25-E27

Conclusión

La SPA aplica autenticación, persistencia temporal y vencimiento de sesión, protege la navegación y adapta sus acciones a los permisos. El token alterado provoca cierre con 401, mientras que un acceso no autorizado conserva la identidad y se comunica como 403. Las restricciones del frontend se complementan con la validación del backend.

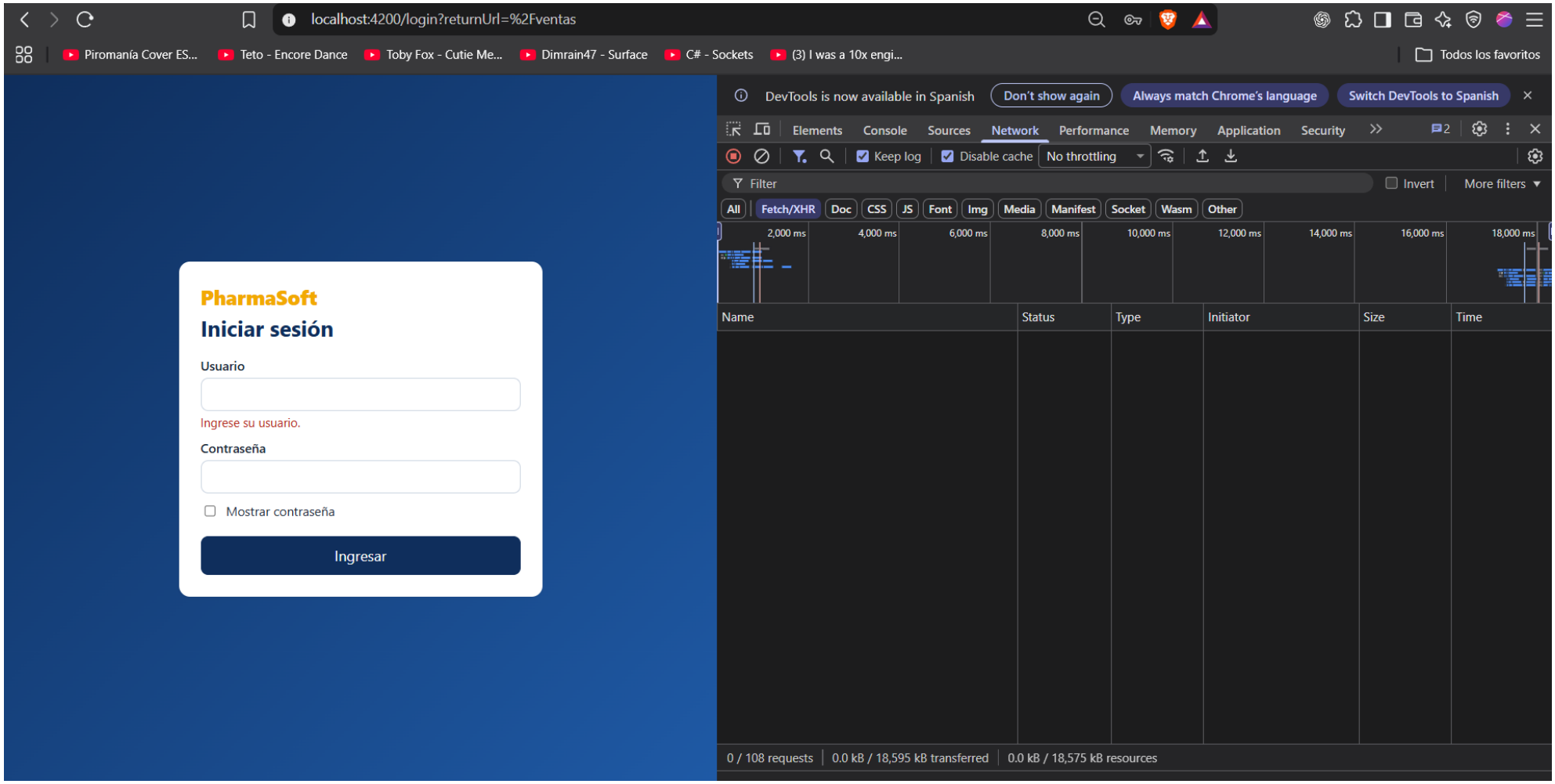
Evidencias

- Acceso y formulario
- Sesión y peticiones HTTP
- Permisos y rutas protegidas
- Cierre de sesión y roles
- Integridad del token y manejo de 401
- Expiración automática y retorno
- Autorización HTTP adicional

Acceso y formulario

E01 · Caso 01 · Ruta protegida sin sesión

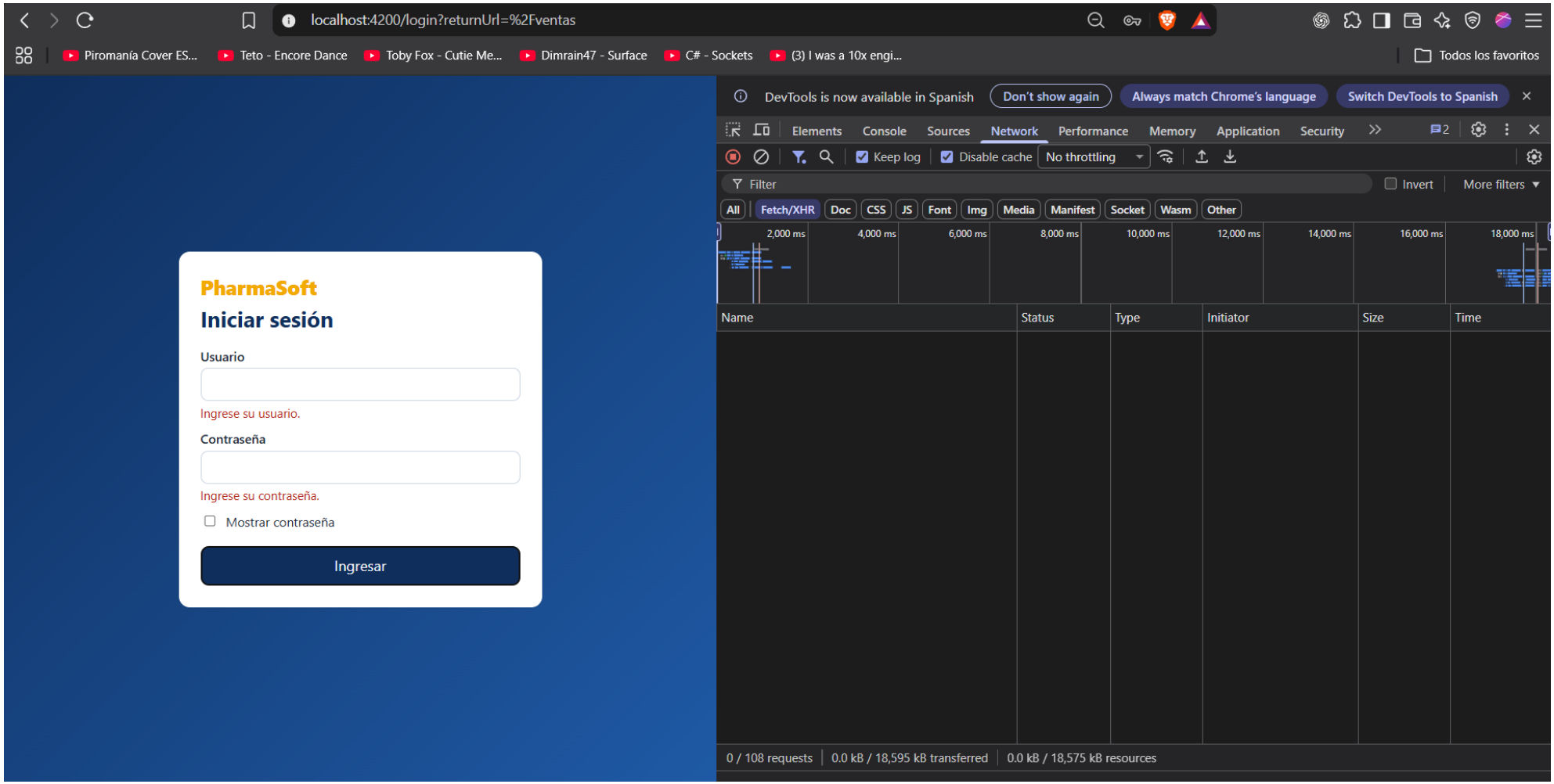
La URL de Ventas redirige al login con returnUrl=%2Fventas. El formulario aparece fuera del layout privado.



Acceso y formulario

E02 · Caso 02 · Validación de campos obligatorios

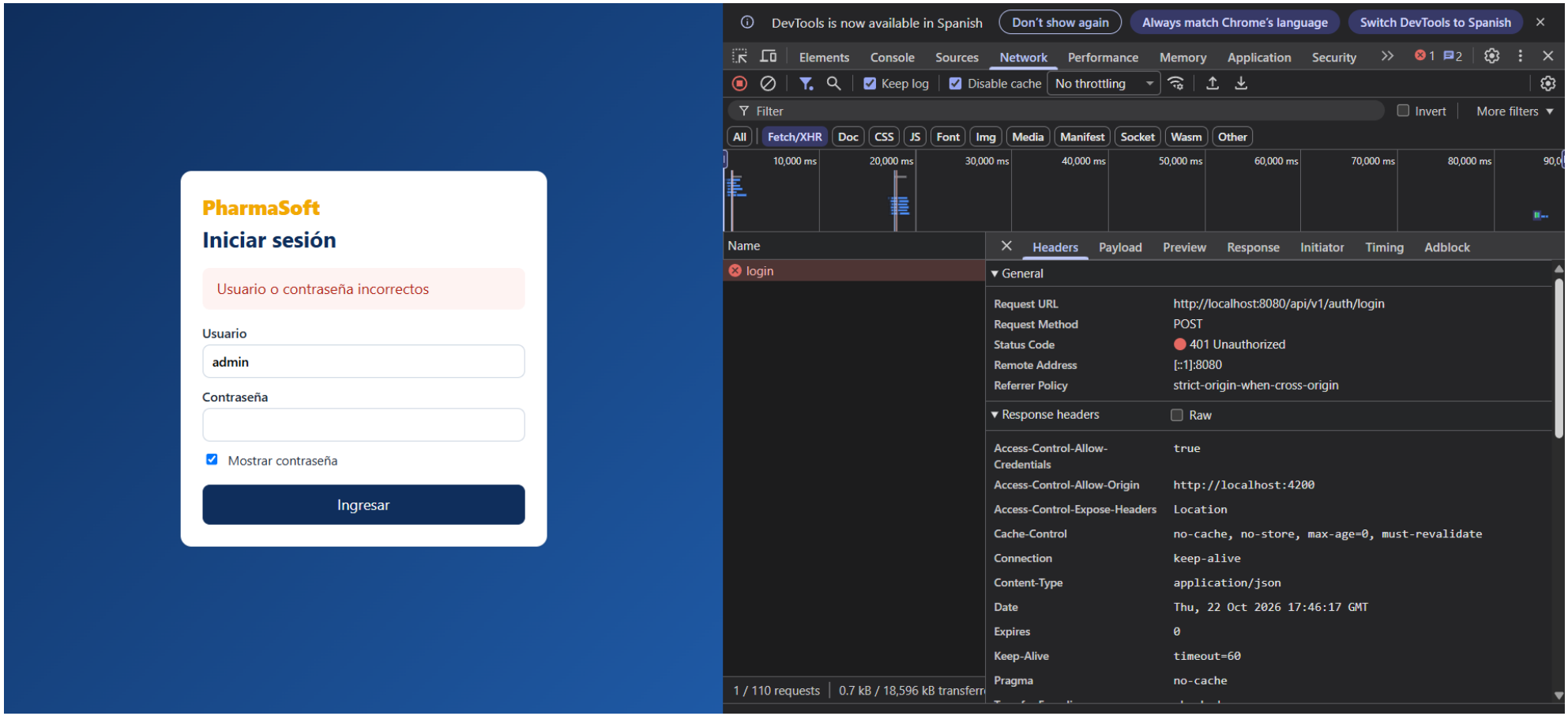
Usuario y contraseña vacíos muestran sus mensajes; Network permanece sin solicitudes de login.



Acceso y formulario

E03 · Caso 03 · Contraseña incorrecta

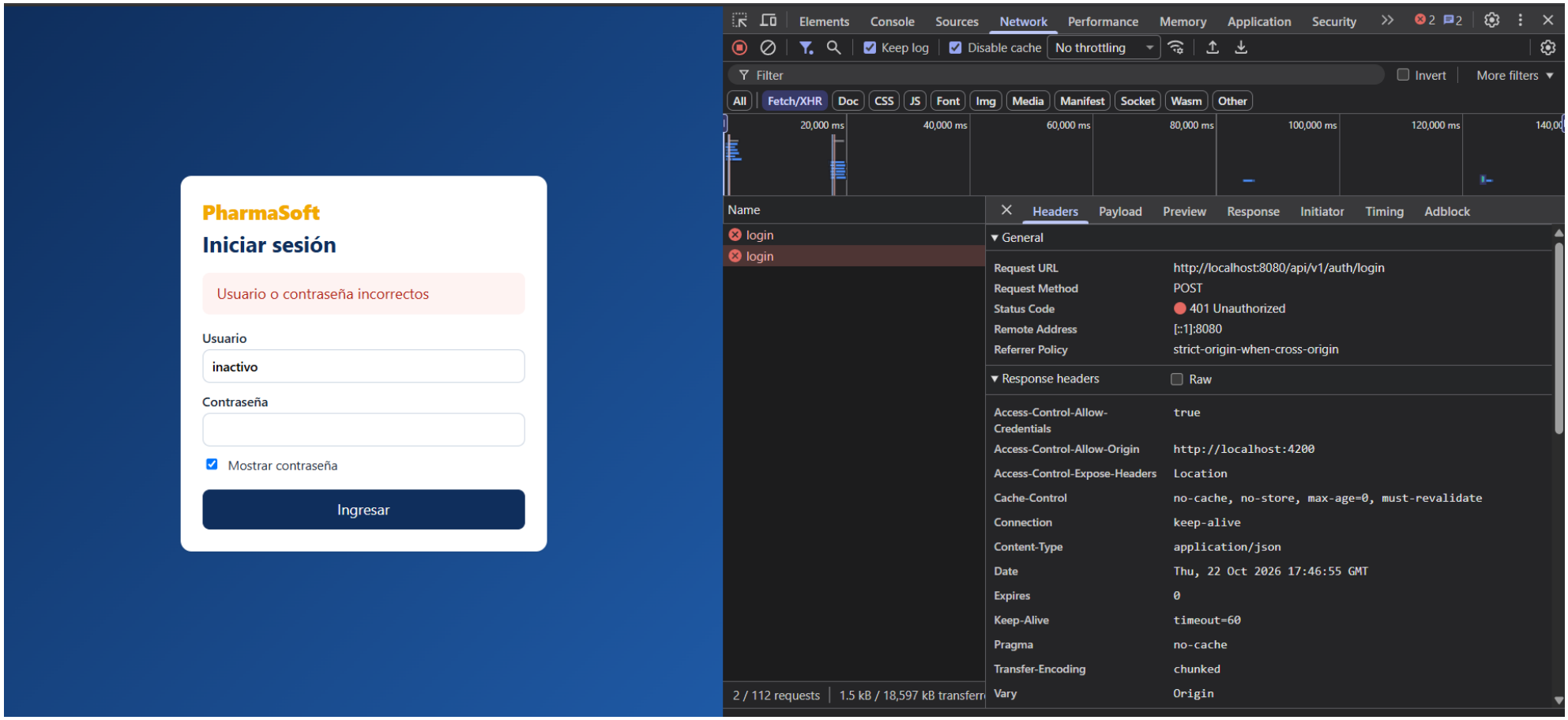
POST auth/login devuelve 401; el formulario muestra Usuario o contraseña incorrectos y conserva el login.



Acceso y formulario

E04 · Caso 04 · Cuenta inactiva

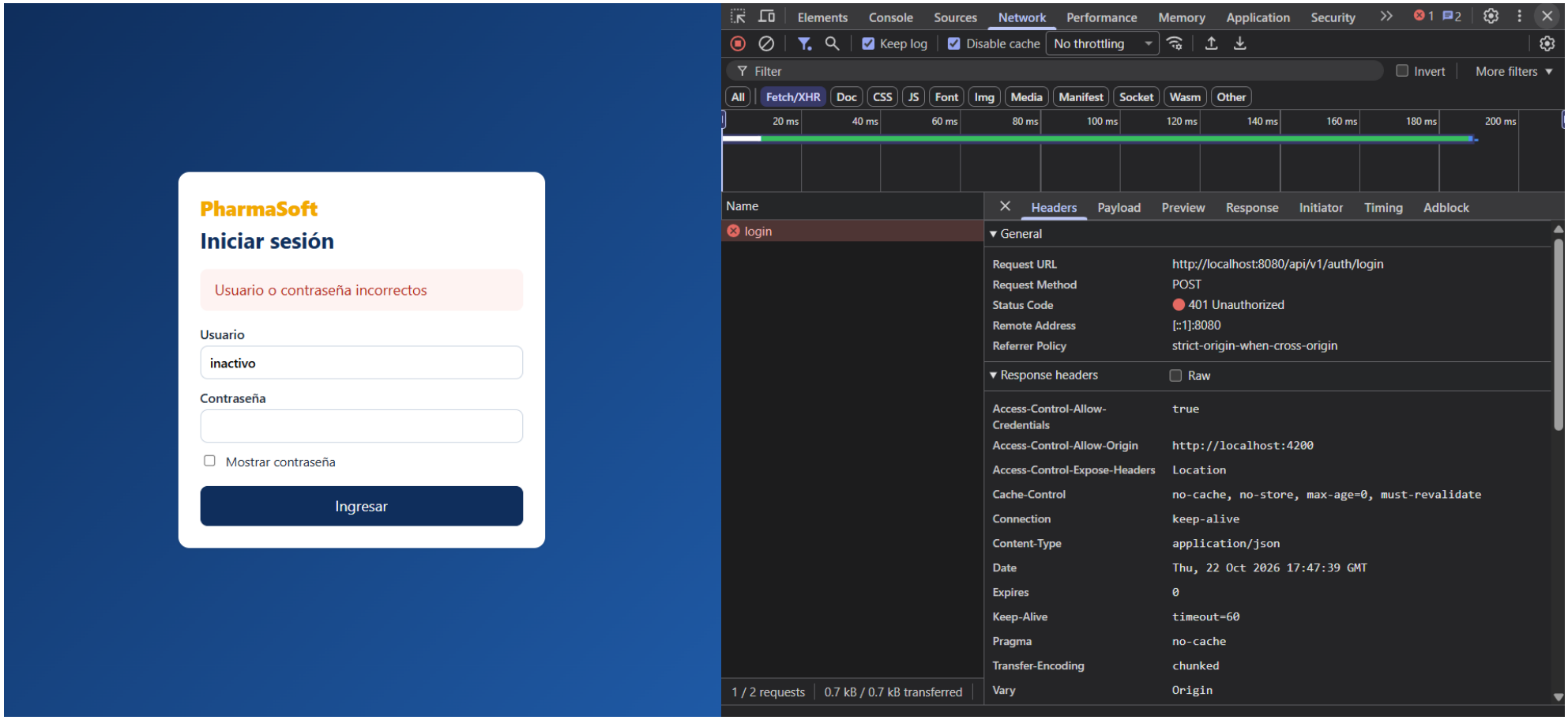
Login de inactivo devuelve 401 y el mismo mensaje genérico de credenciales.



Acceso y formulario

E05 · Caso 04 · Cuenta inactiva: comprobación adicional

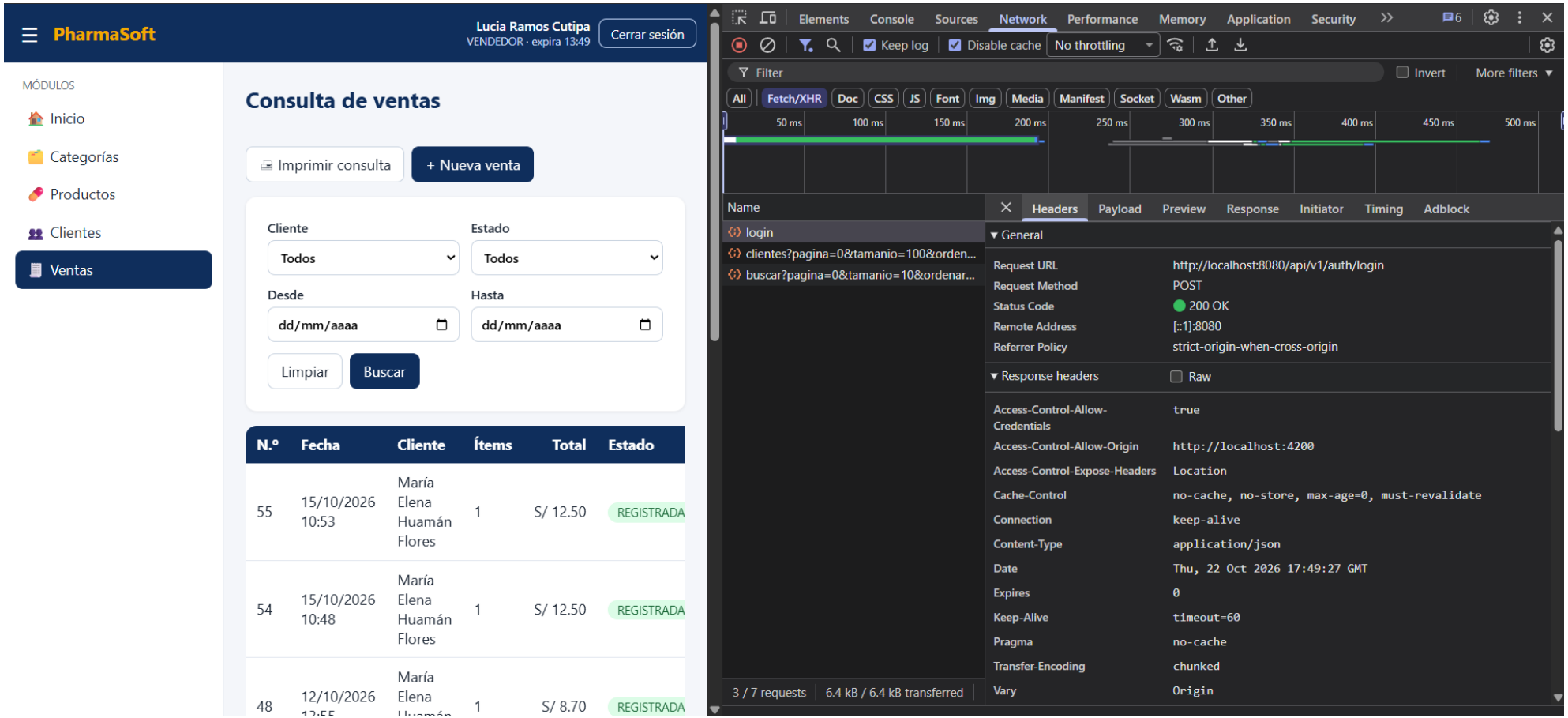
Se confirma el rechazo 401 sin revelar al usuario que la cuenta existe o está deshabilitada.



Sesión y peticiones HTTP

E06 · Caso 05 · Login y retorno a Ventas

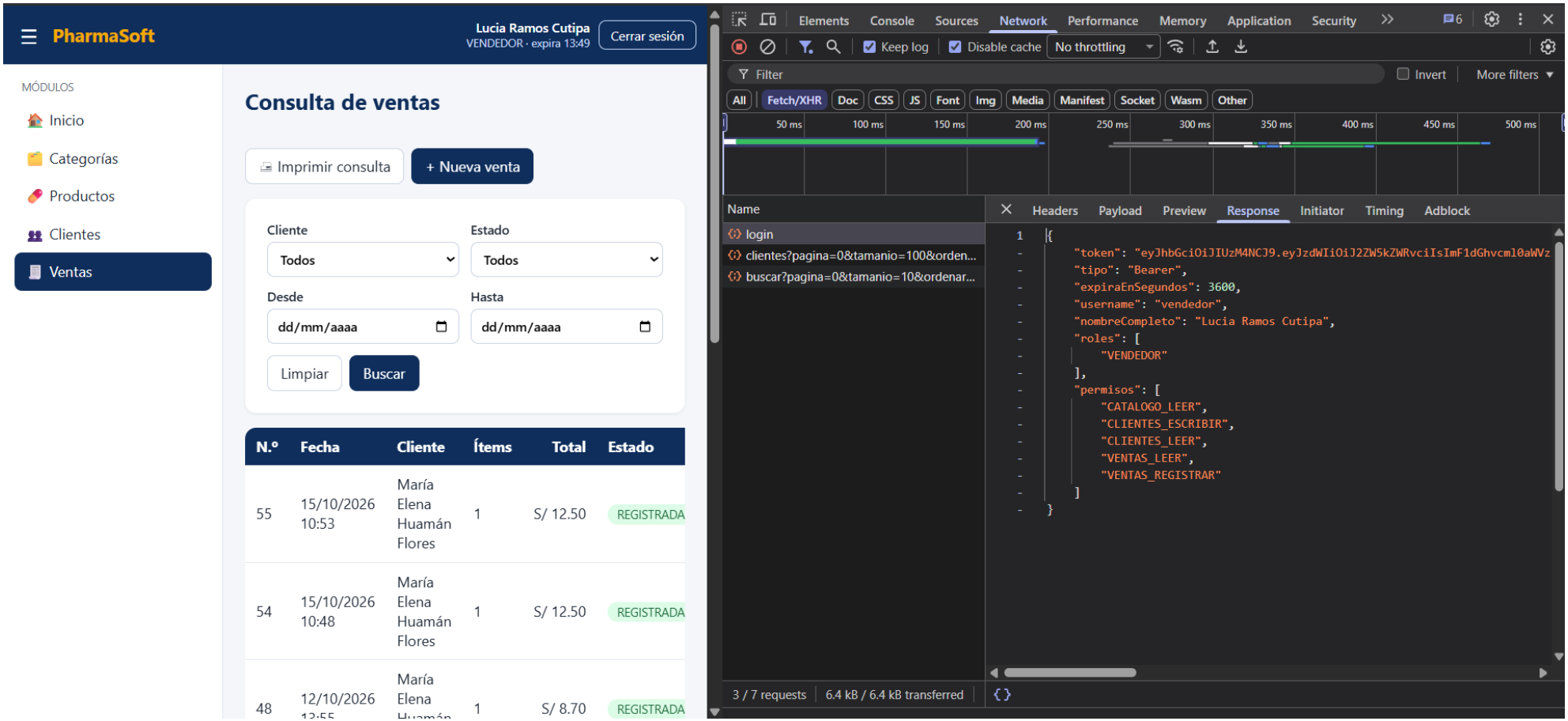
Login 200; se abre Consulta de ventas y el encabezado identifica a Lucia Ramos Cutipa, VENDEDOR, con su hora de expiración.



Sesión y peticiones HTTP

E07 · Caso 05 · Respuesta de autenticación

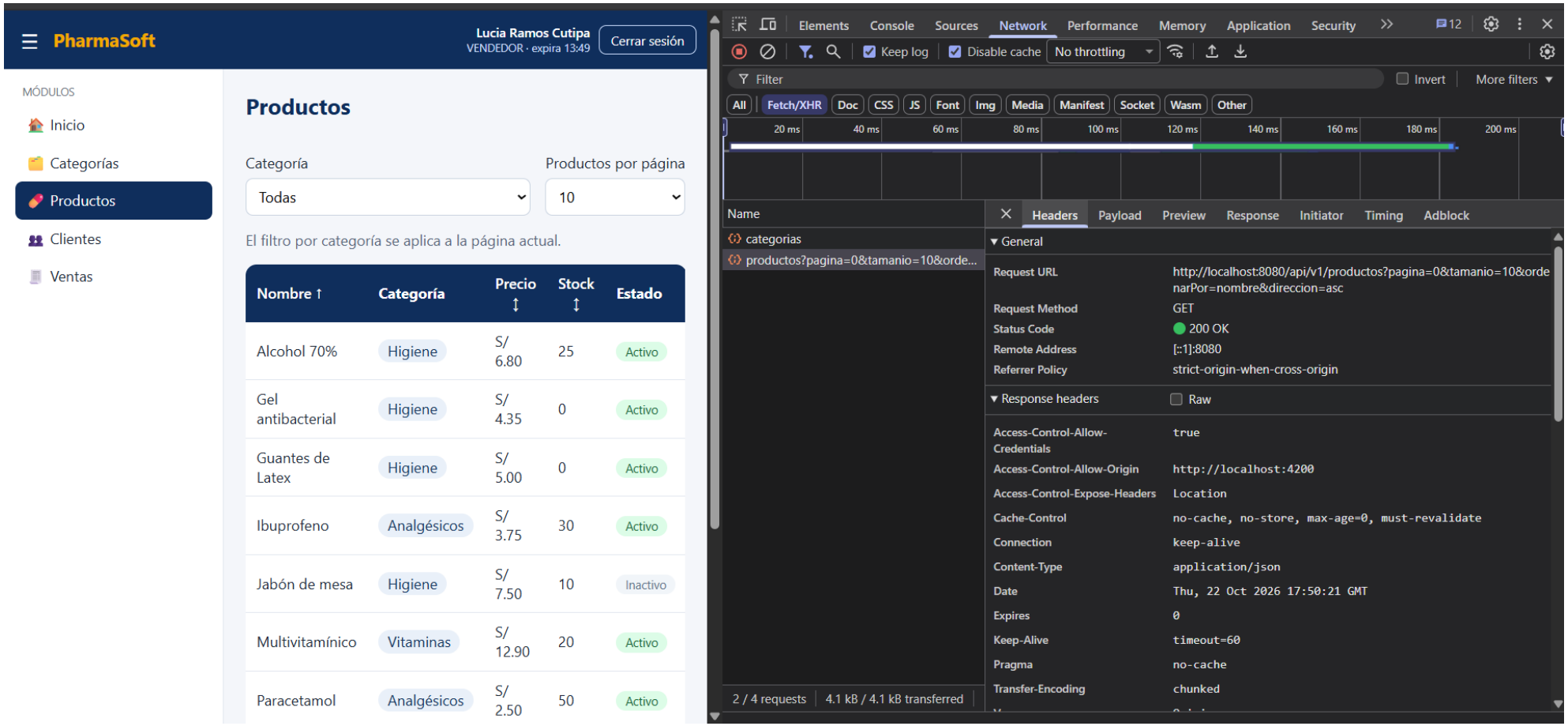
La respuesta de login incluye token, expiración, nombre, roles y permisos del vendedor.



Sesión y peticiones HTTP

E08 · Caso 06 · Consulta autenticada del catálogo

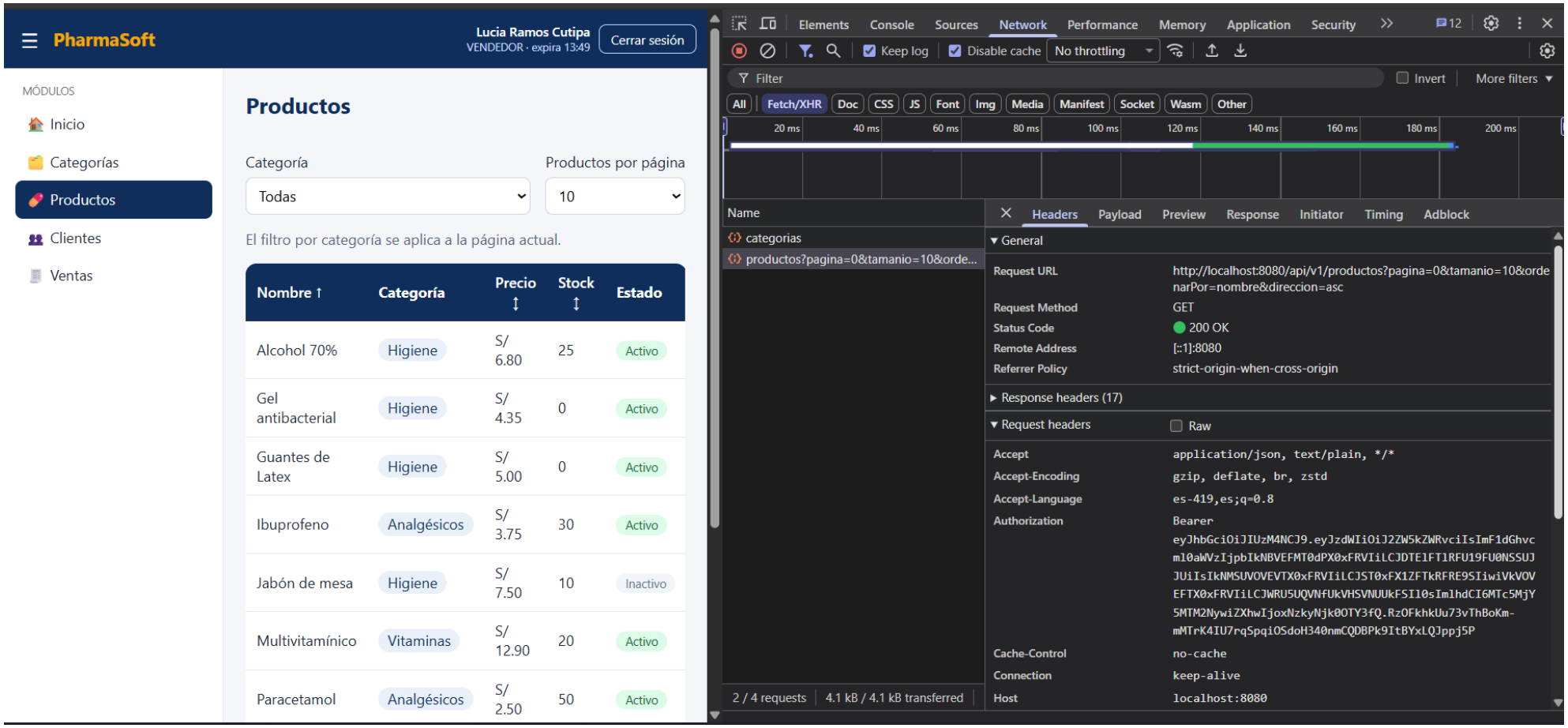
GET productos devuelve 200 desde la SPA con sesión iniciada.



Sesión y peticiones HTTP

E09 · Caso 06 · Encabezado Authorization

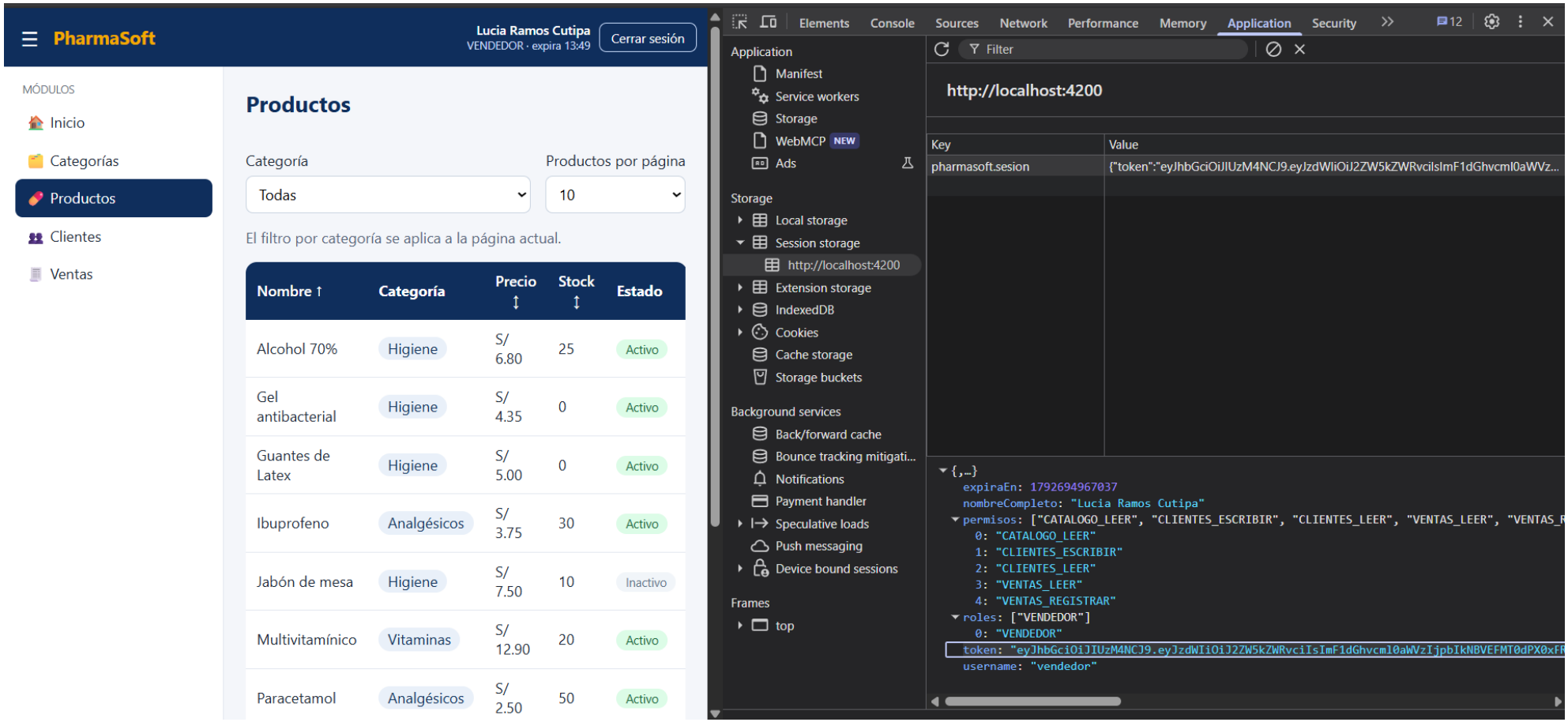
El GET productos muestra Authorization: Bearer seguido del JWT en Request Headers.



Sesión y peticiones HTTP

E10 · Caso 07 · Sesión almacenada en el navegador

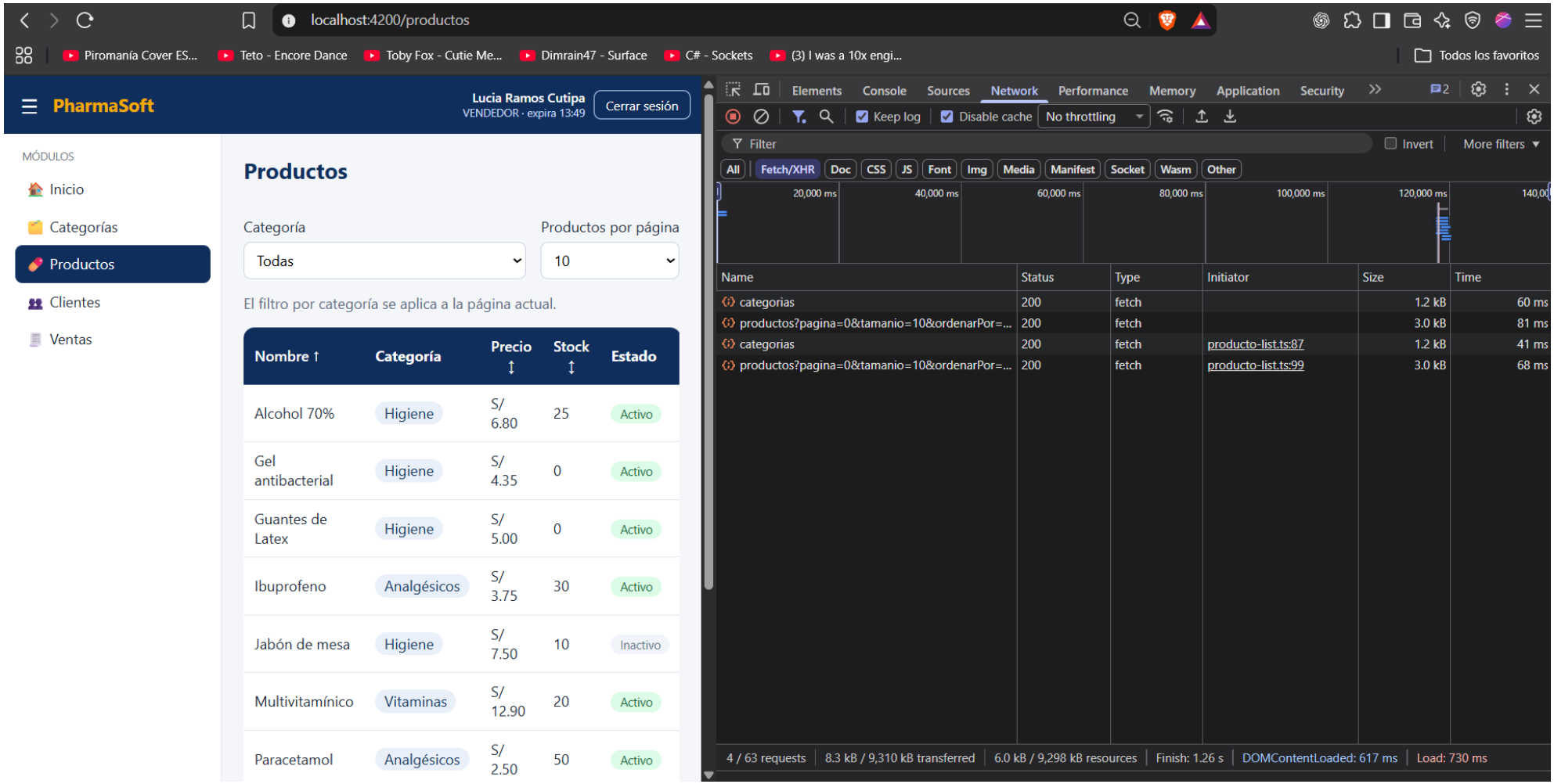
Session storage contiene pharmasoft.sesion y sus datos de perfil, permisos y token. No contiene la contraseña de acceso.



Sesión y peticiones HTTP

E11 · Caso 08 · Persistencia después de F5

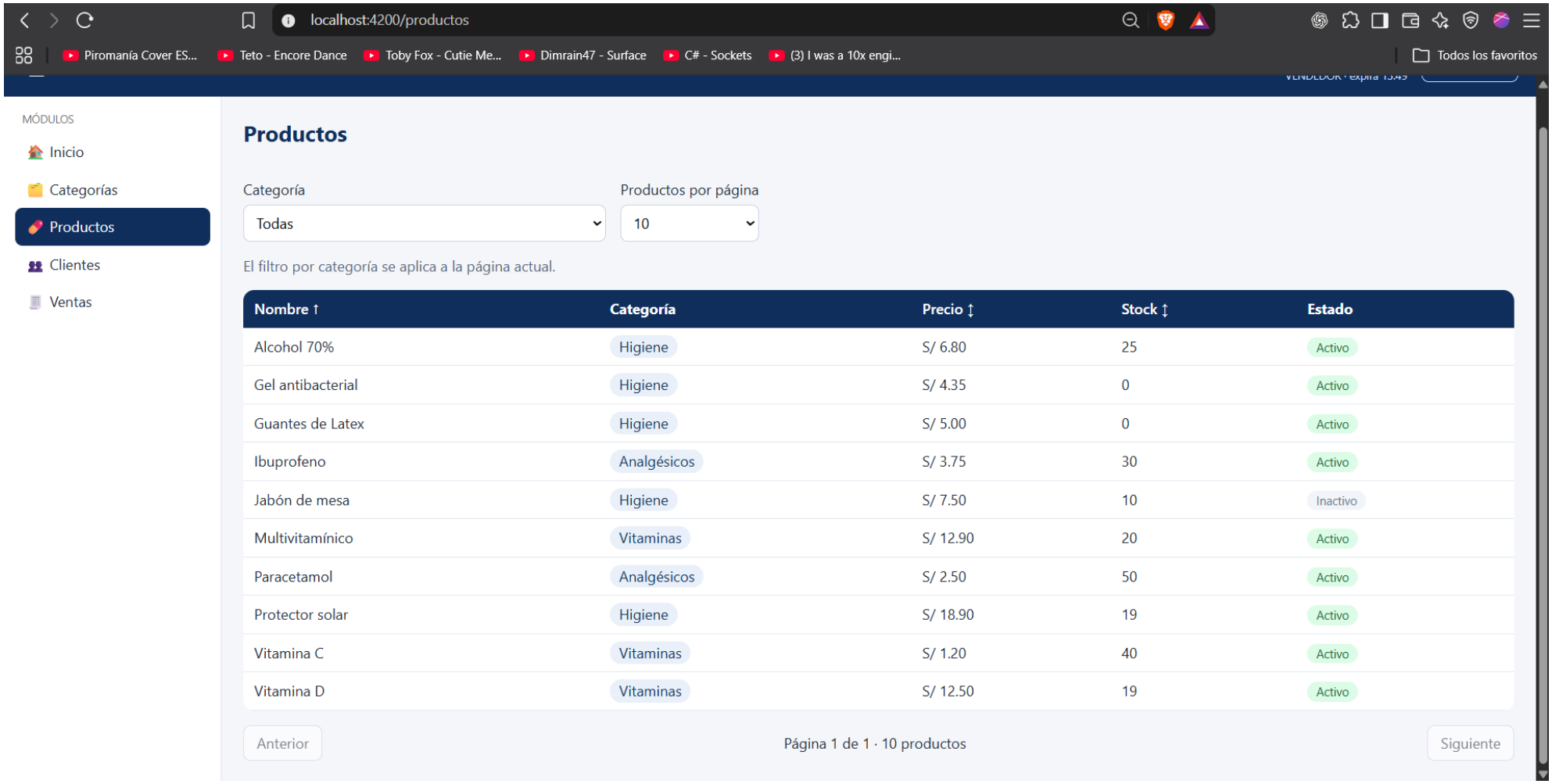
Productos se mantiene con la cuenta del vendedor; las consultas del catálogo vuelven a responder 200 después de recargar.



Permisos y rutas protegidas

E12 · Caso 09 · Productos en modo lectura

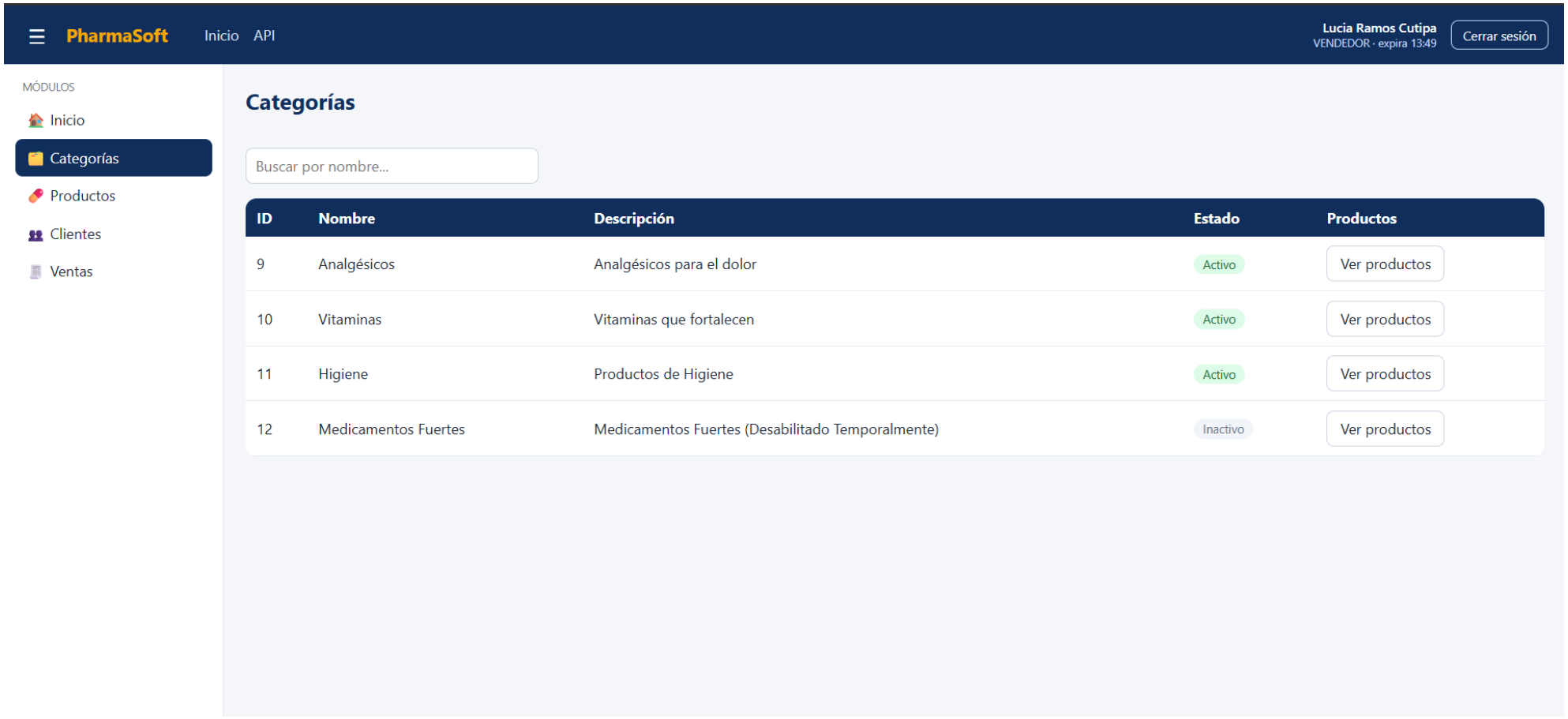
VENDEDOR ve el catálogo completo sin Nuevo producto ni columna Acciones.



Permisos y rutas protegidas

E13 · Caso 09 · Categorías en modo lectura

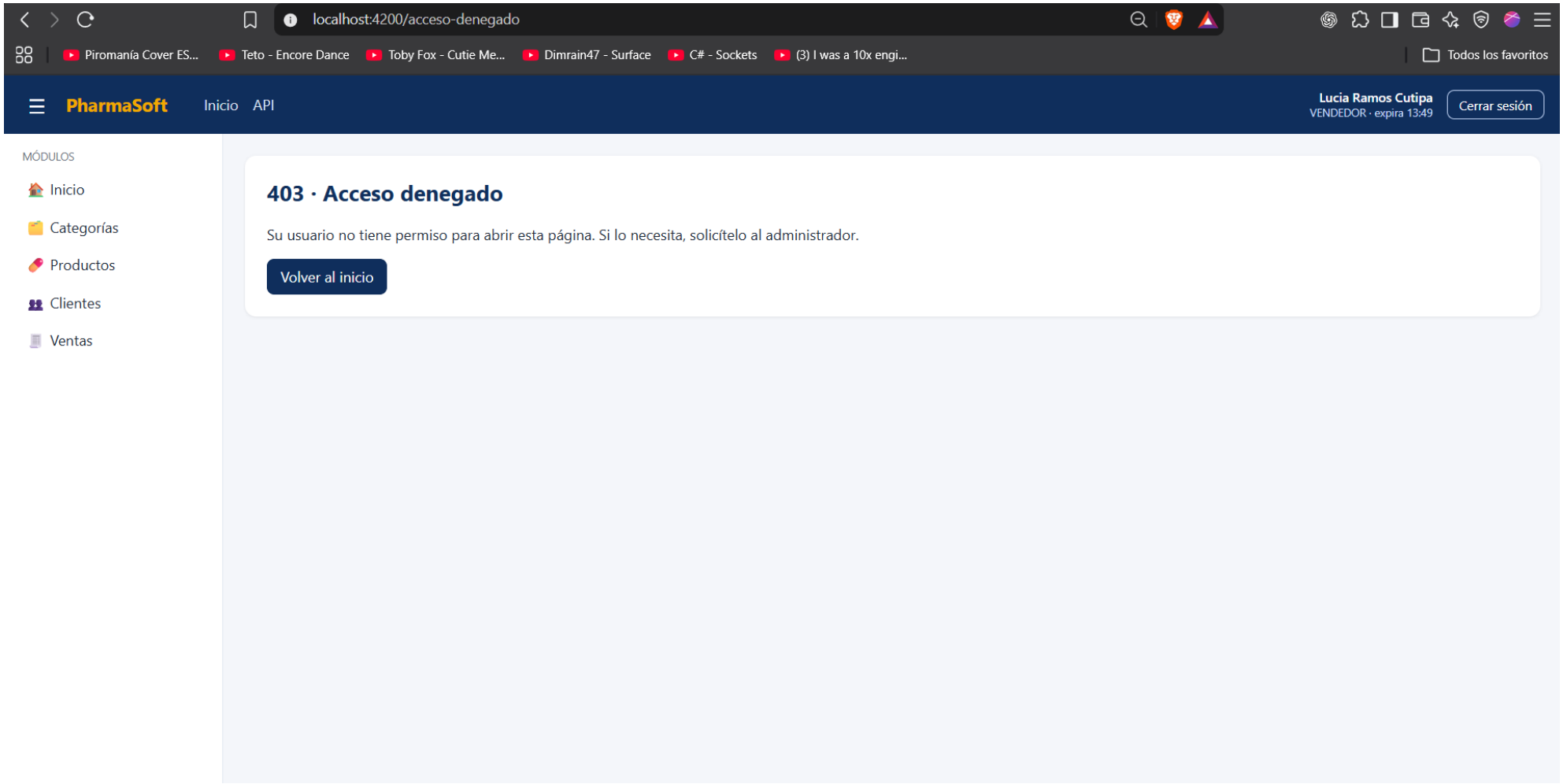
El vendedor conserva Ver productos, pero no tiene controles para crear, editar o eliminar categorías.



Permisos y rutas protegidas

E14 · Caso 10 · Creación bloqueada por el guard

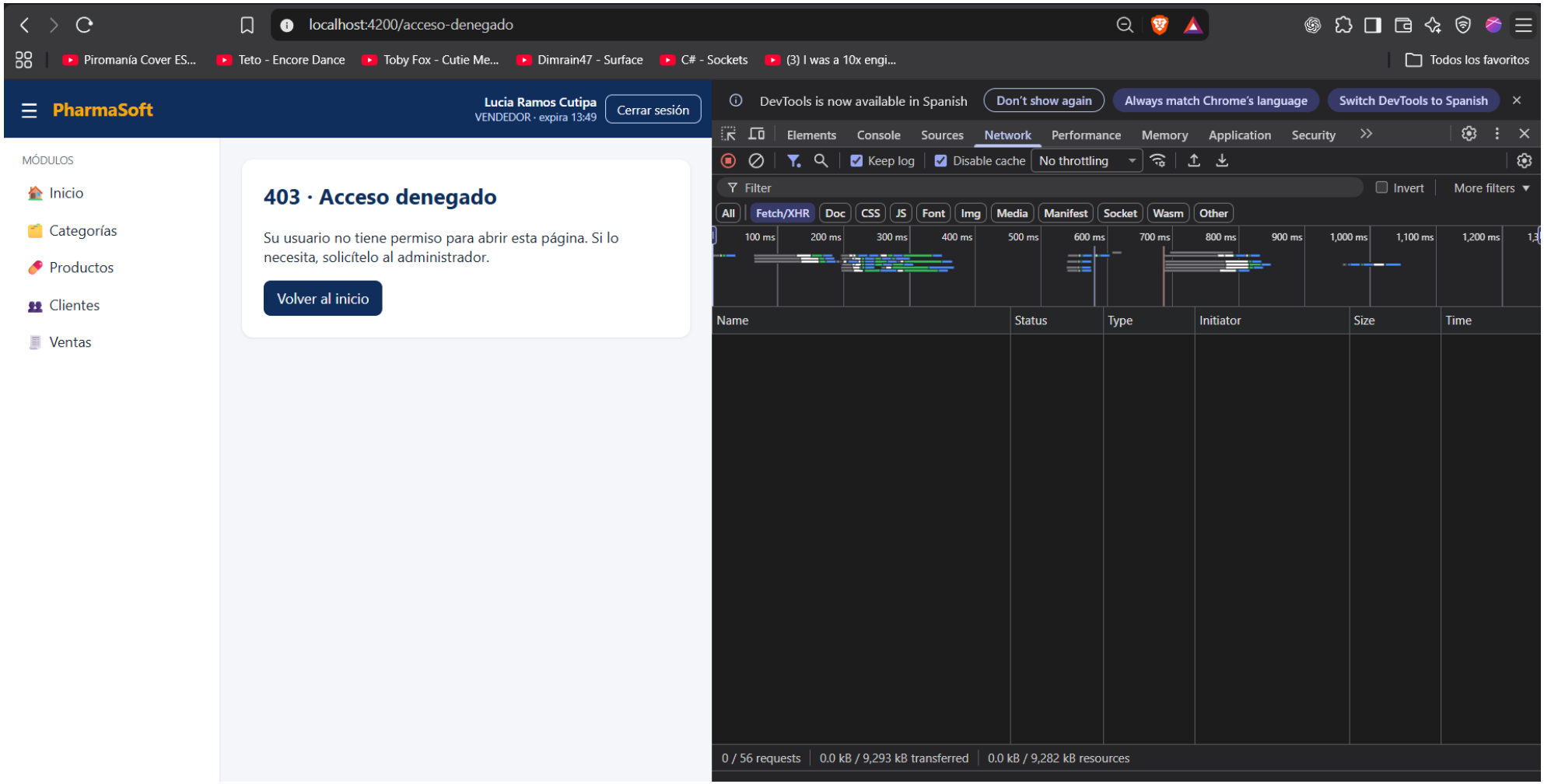
La navegación sin CATALOGO_ESCRIBIR termina en /acceso-denegado, con título 403 · Acceso denegado y sesión vigente.



Permisos y rutas protegidas

E15 · Caso 10 · Bloqueo de ruta y sesión conservada

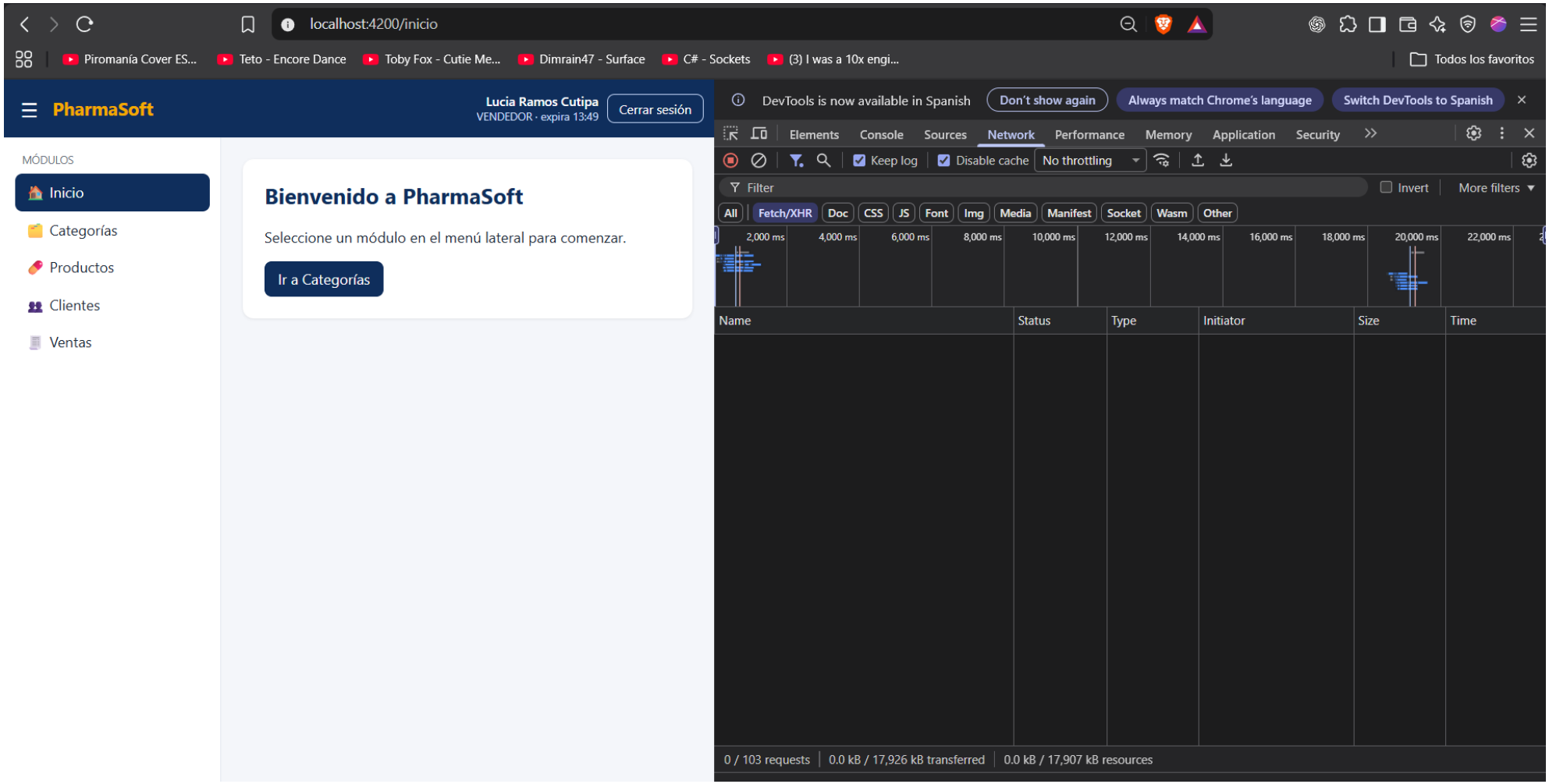
El mensaje de acceso denegado se presenta dentro del layout del vendedor. Es una decisión del guard, no un error HTTP del formulario de alta.



Permisos y rutas protegidas

E16 · Caso 11 · Login inaccesible con sesión iniciada

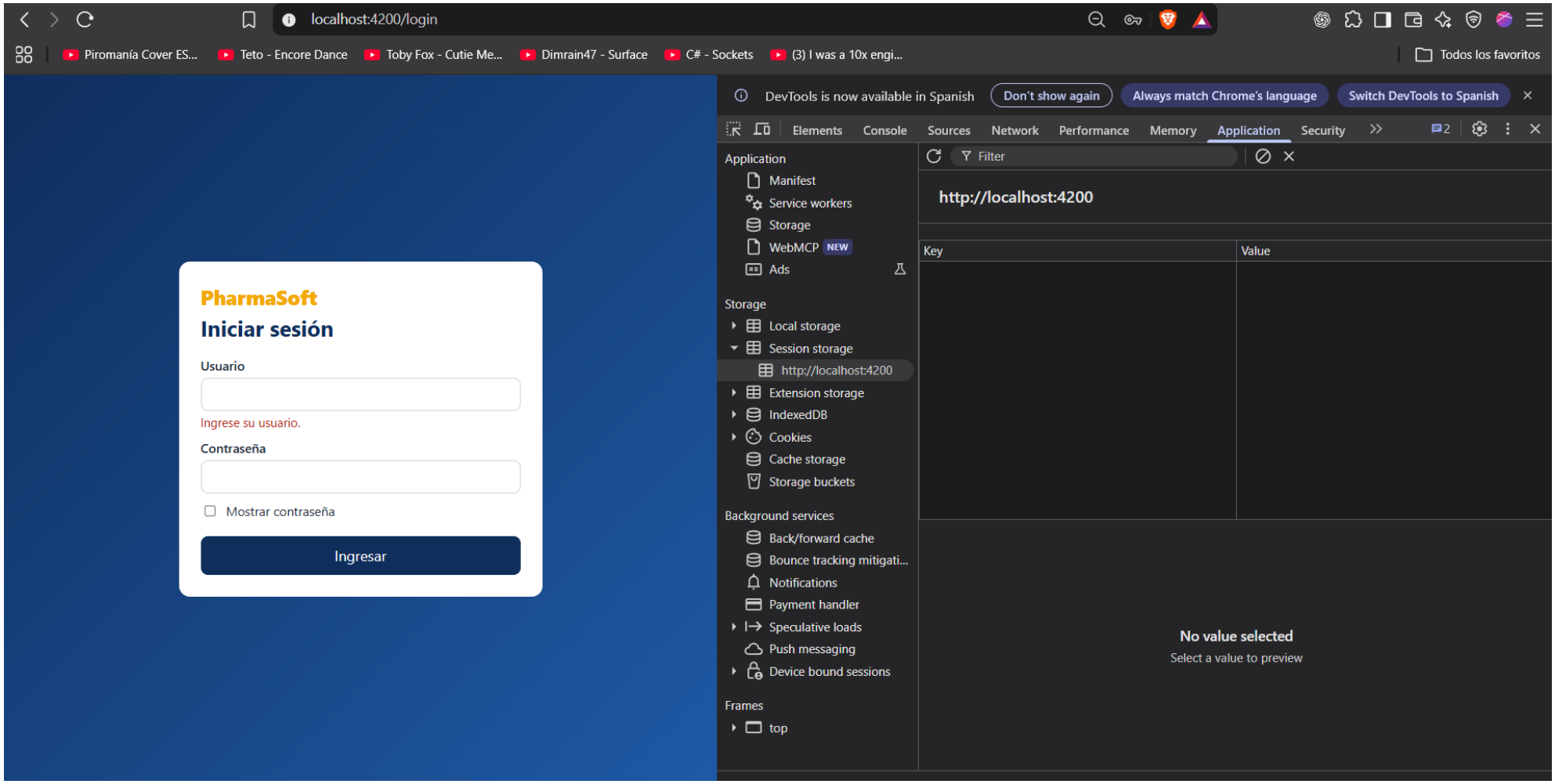
invitadoGuard lleva a /inicio; el encabezado y el menú permanecen asociados al vendedor.



Cierre de sesión y roles

E17 · Caso 12 · Logout y eliminación del almacenamiento

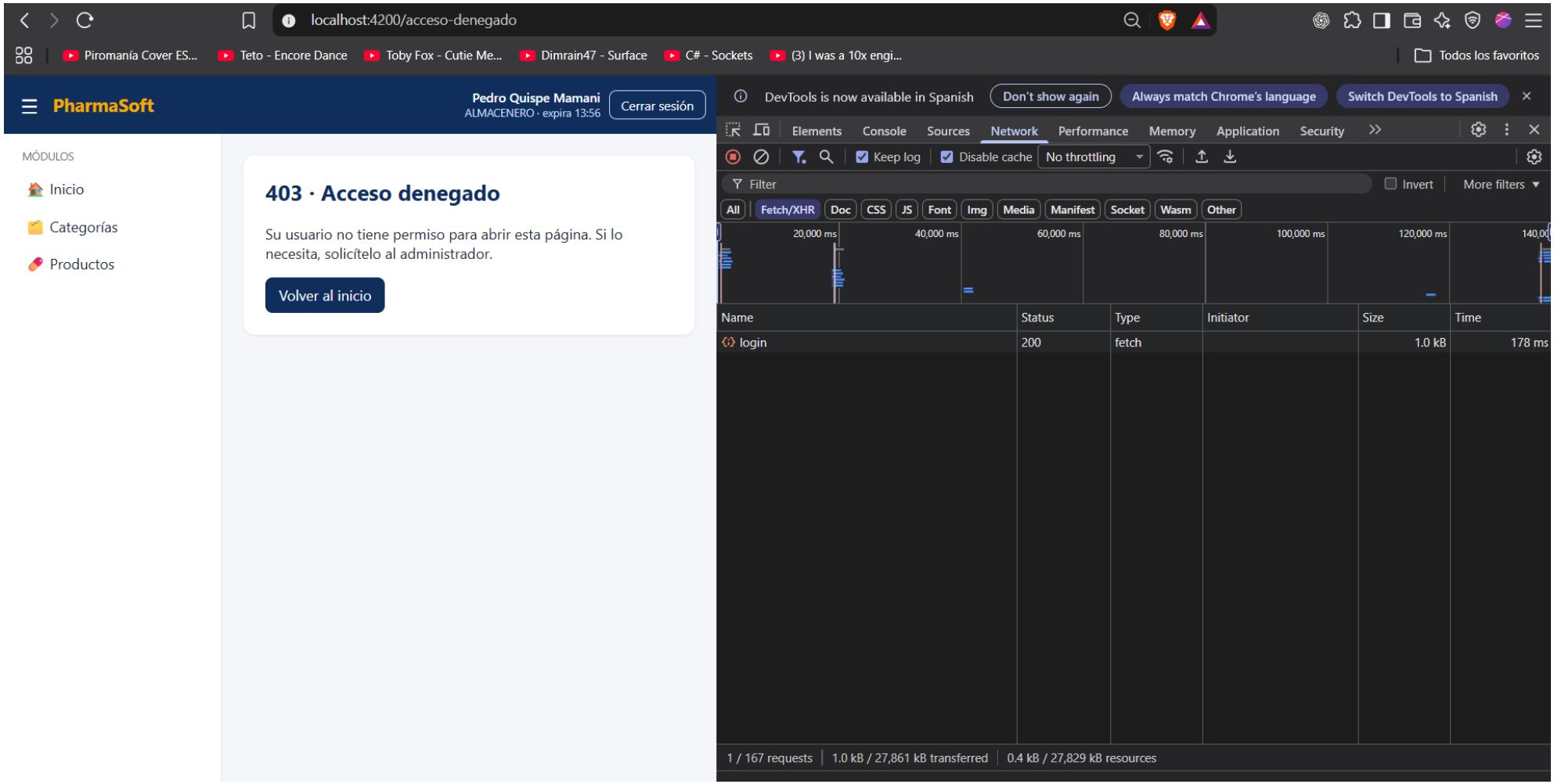
La aplicación vuelve al login y Session storage ya no contiene pharmasoft.sesion.



Cierre de sesión y roles

E18 · Caso 13 · Almacén no puede acceder a Ventas

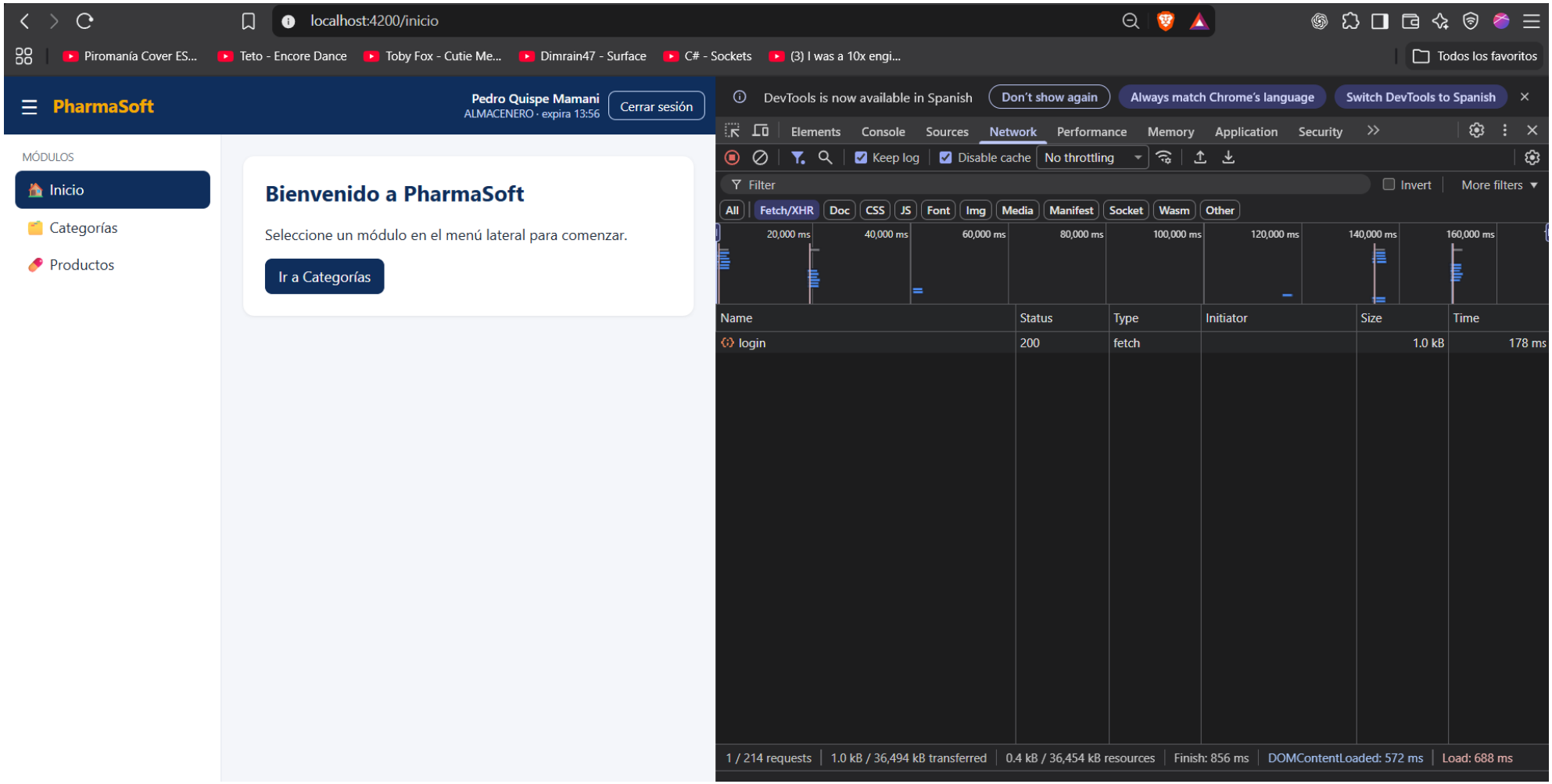
ALMACENERO no tiene Ventas en el menú y la navegación directa muestra Acceso denegado sin cerrar la sesión.



Cierre de sesión y roles

E19 · Caso 13 · Menú de almacén

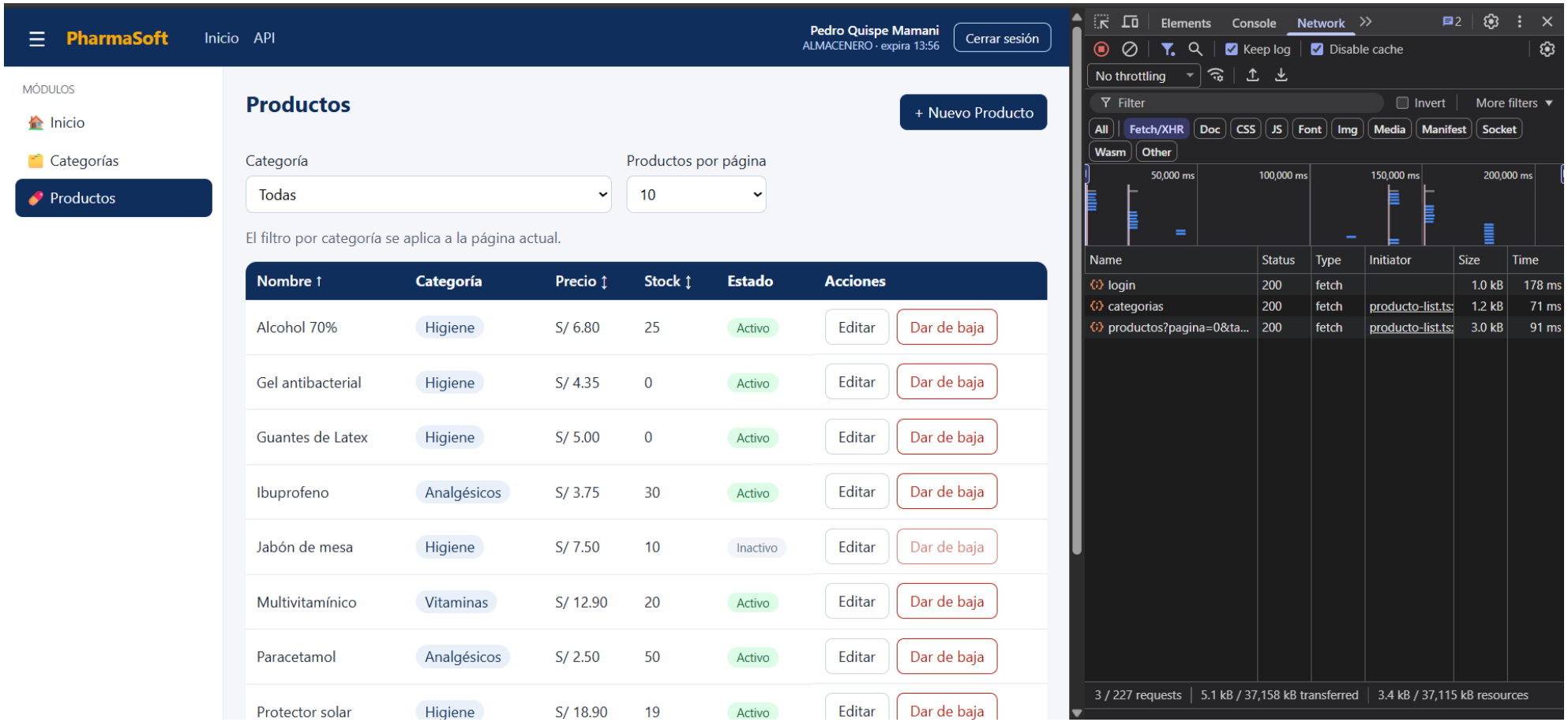
El menú de Pedro Quispe Mamani contiene Inicio, Categorías y Productos; no expone Clientes, Ventas ni Reportes.



Cierre de sesión y roles

E20 · Caso 13 · Catálogo editable para almacén

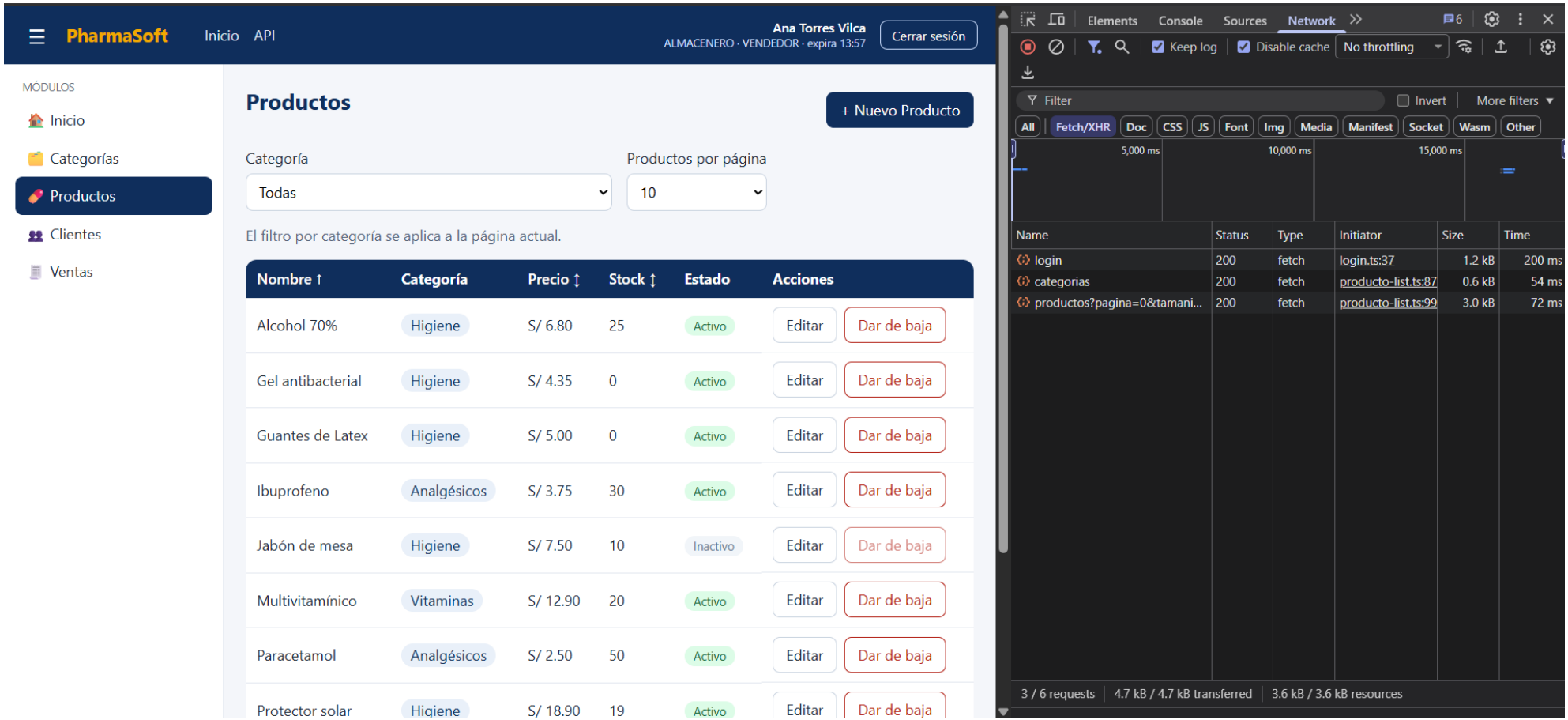
La cuenta ALMACENERO muestra Nuevo producto, Editar y Dar de baja. La comprobación no ejecuta esas operaciones.



Cierre de sesión y roles

E21 · Caso 14 · Supervisor con unión de permisos

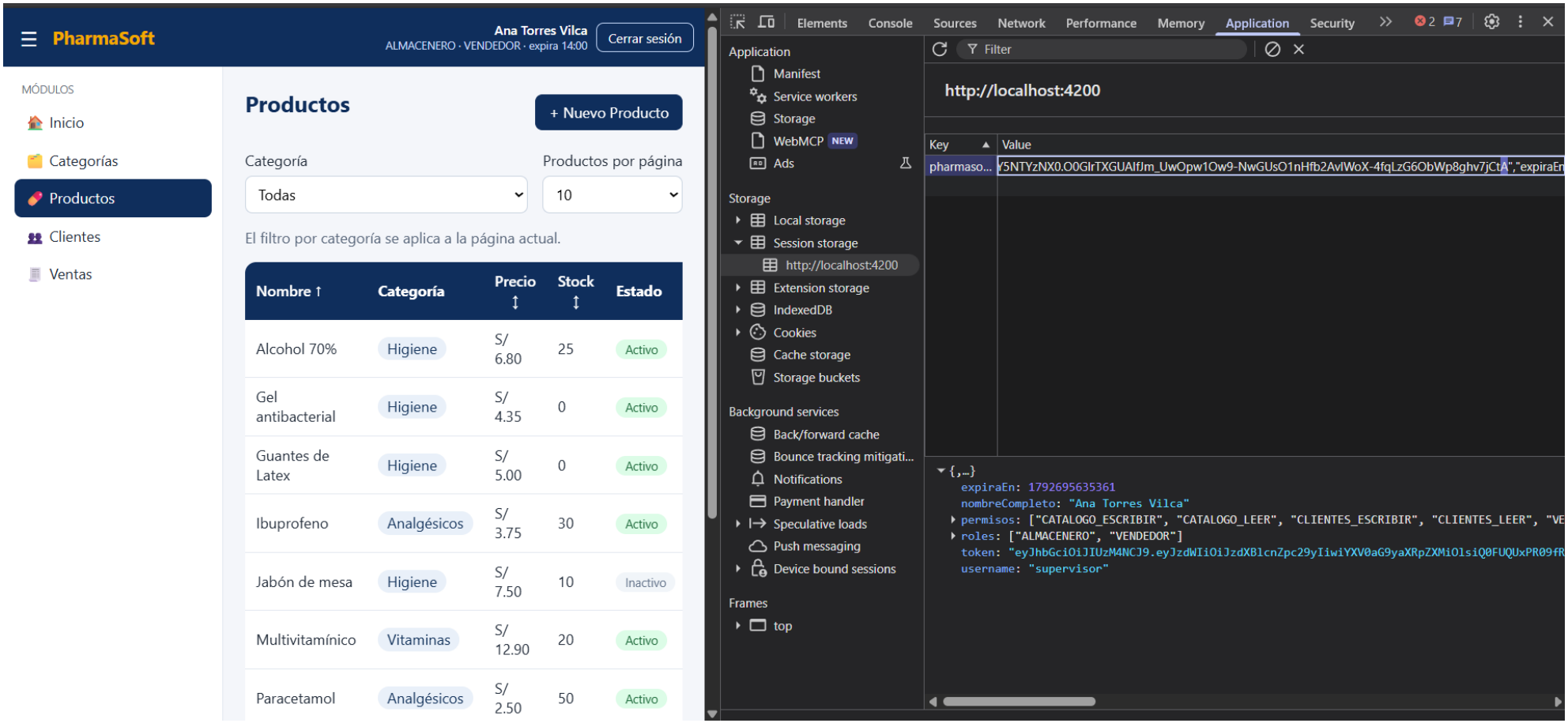
Ana Torres Vilca presenta ALMACENERO y VENDEDOR: Ventas aparece en el menú y el catálogo muestra controles de edición.



Integridad del token y manejo de 401

E22 · Caso 15 · Sesión antes de alterar el token

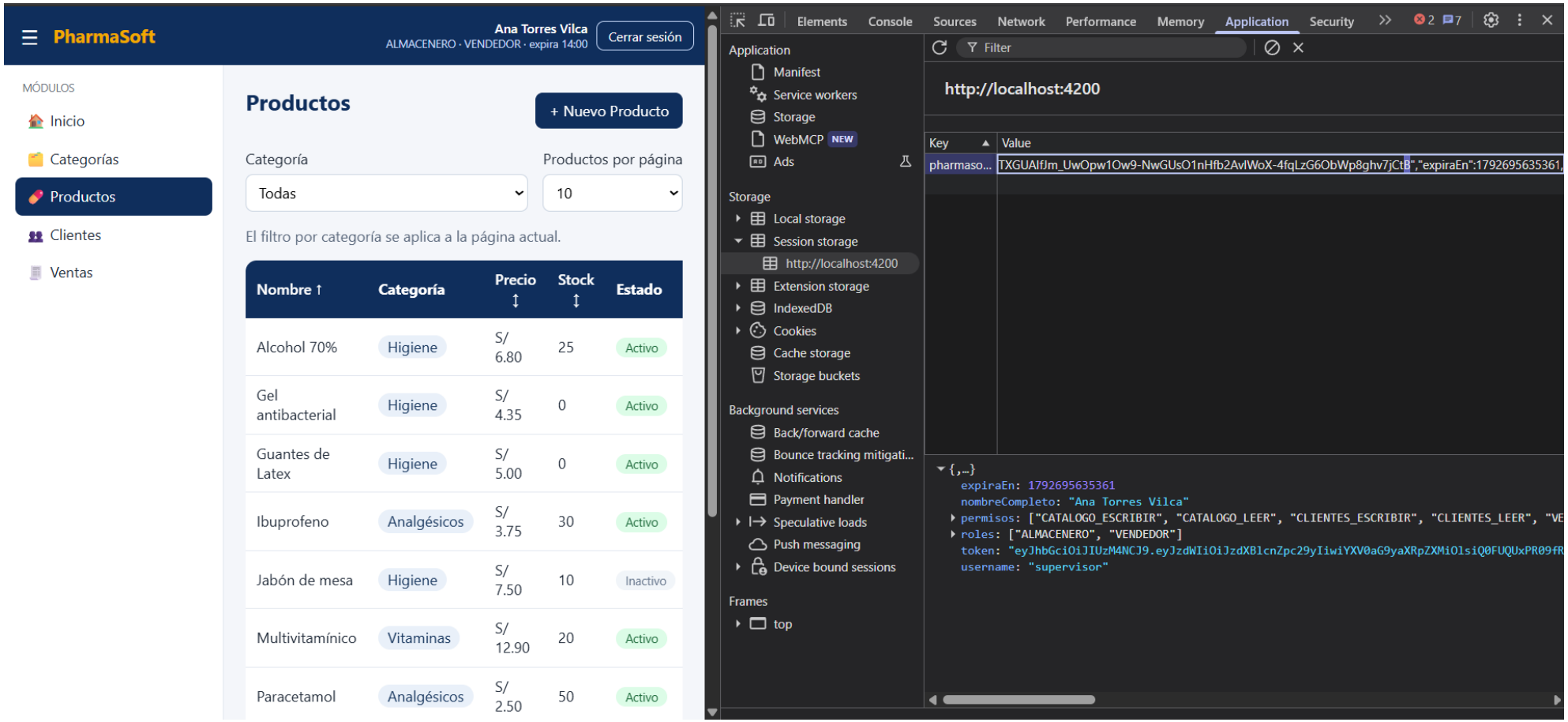
La sesión de supervisor se inspecciona en Session storage antes de modificar el JWT.



Integridad del token y manejo de 401

E23 · Caso 15 · Edición controlada del token

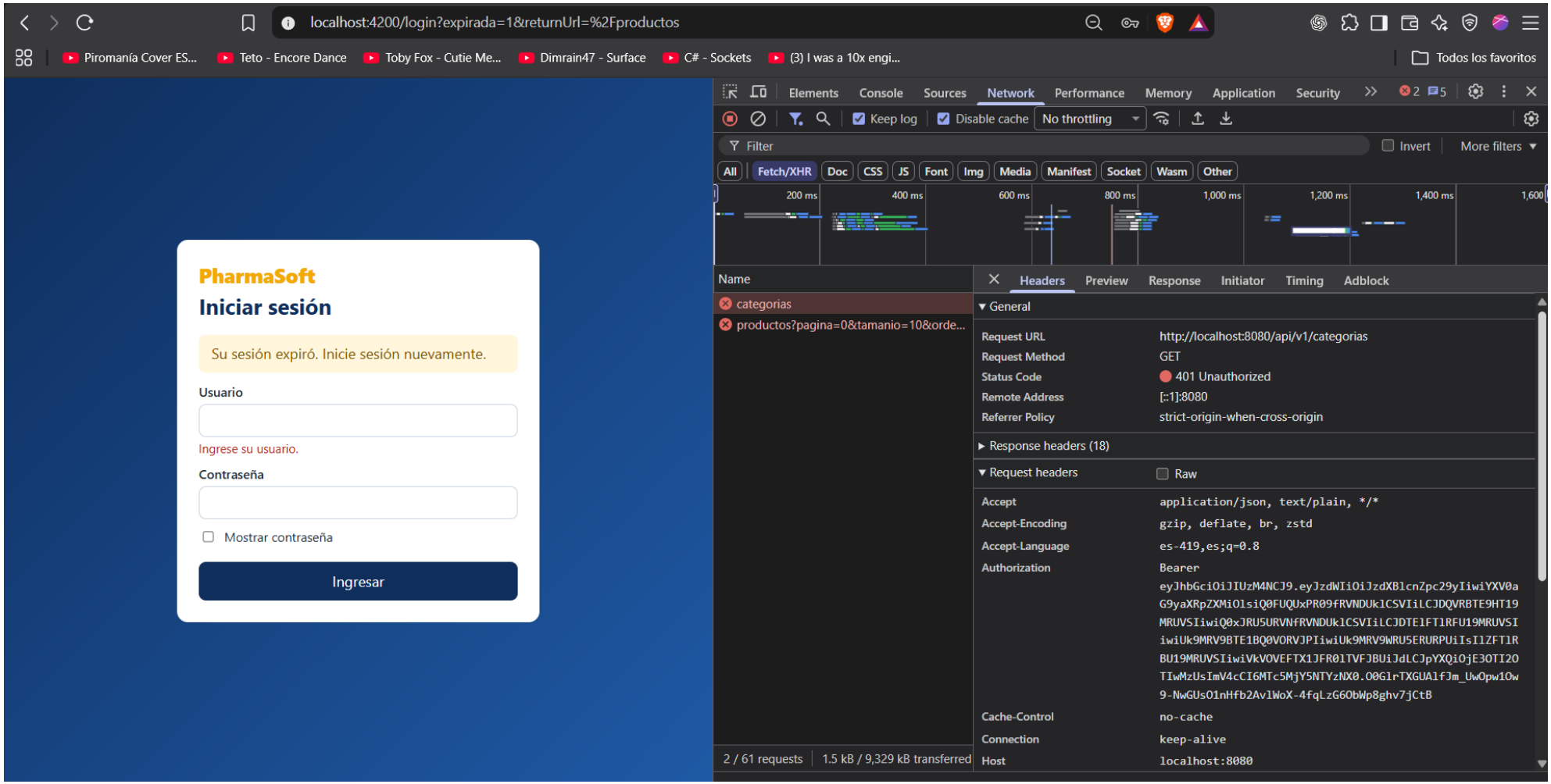
Se edita el token dentro del JSON de pharmasoft.sesion, manteniendo los demás datos de la sesión.



Integridad del token y manejo de 401

E24 · Caso 15 · Rechazo del token alterado

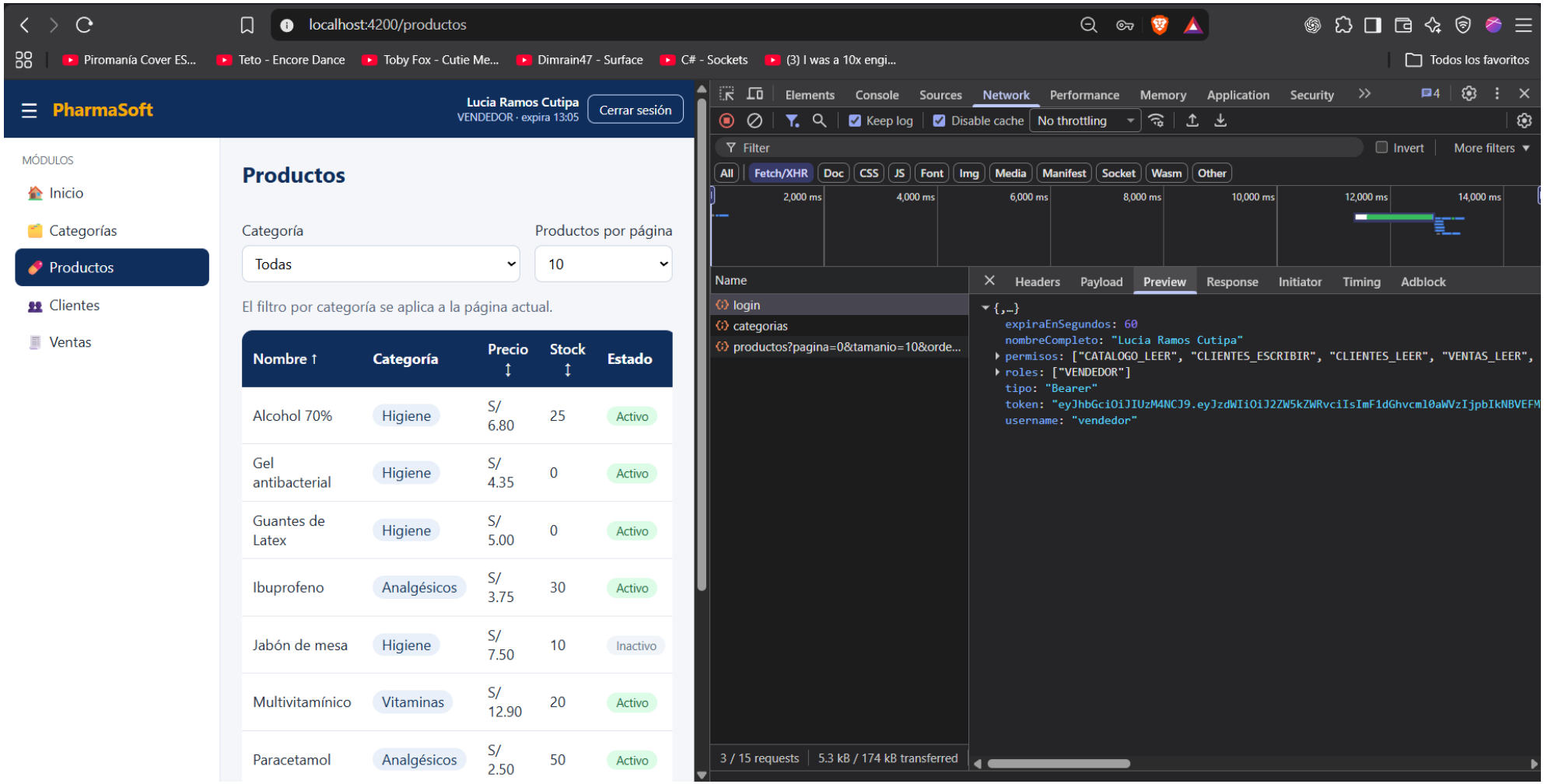
GET categorías responde 401 tras la recarga; la SPA vuelve al login con expirada=1, returnUrl a Productos y el aviso Su sesión expiró.



Expiración automática y retorno

E25 · Caso 16 · Emisión de un token de un minuto

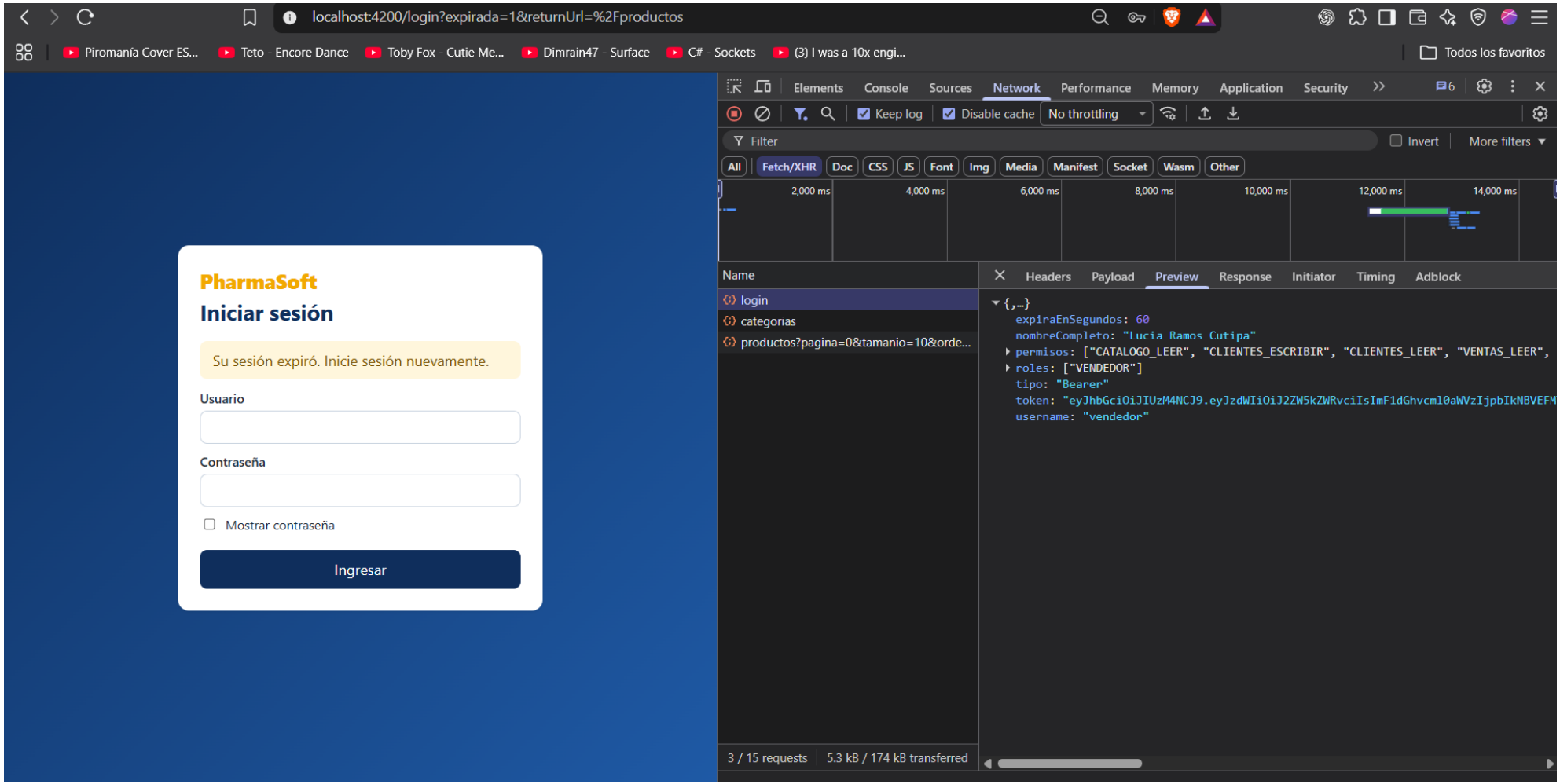
Login de vendedor devuelve expiraEnSegundos: 60. Productos permanece disponible antes de que venza el temporizador.



Expiración automática y retorno

E26 · Caso 16 · Cierre automático al vencer

La SPA vuelve al login con el aviso de expiración y returnUrl=%2Fproductos. Se conserva la respuesta de login con duración 60 segundos.



Autorización HTTP adicional

E27 · Caso AD · Reporte prohibido sin cerrar sesión

Una consulta GET al reporte con fetch devuelve 403 y el mensaje No tiene permisos para realizar esta operación; el vendedor sigue en Productos. La petición usa fetch y no atraviesa los interceptores de Angular.

